

THIRD-PARTY / OPEN BANKING TAXONOMY AUDIT

PART 3 – FINAL TAXONOMY

FAMILY OB-001: CONSENT ABUSE (Single Consent / Broad Consent Exploitation)

A. Identity

Field	Value
Attack ID	OB-001
Attack Family	Consent Abuse / Broad Consent Exploitation
Variants	Single consent exploitation; Broad scope abuse; Consent deception; Fine-print exploitation; Consent phishing
Primary Lifecycle Stage	Third-Party / Open Banking (Consent Granting)
Cross-stage Stages	Account Creation (data harvested for synthetic identities); Payment Initiation (consent used for PISP fraud); AML/Compliance (mule activity)
Attacker	Fraudulent TPP; Malicious fintech; AI-powered social engineering agent; Organised fraud ring
Target	Open banking customers; Account Aggregator users; PSD2 consent flows; Financial institutions' consent systems
Objective	Obtain broader data access or payment permissions than the customer intended, enabling downstream fraud
Third-party Control Targeted	Consent scope; Customer consent decision; Delegated authority; Consent duration and revocation

B. Fraud Understanding

What is the attack?

Attackers use GenAI to create hyper-personalised, convincing consent requests that trick customers into granting overly broad financial data access or payment permissions. The customer authenticates legitimately (Strong Customer Authentication) but is deceived into approving more than they intended. Consent is the heart of open banking—and also its greatest vulnerability.

Traditional mechanism:

Before GenAI, consent abuse relied on:

- Manual social engineering (phone calls, generic emails)
- Fine-print exploitation (customers skipping consent details)
- Basic phishing pages (detectable, generic)

GenAI transformation:

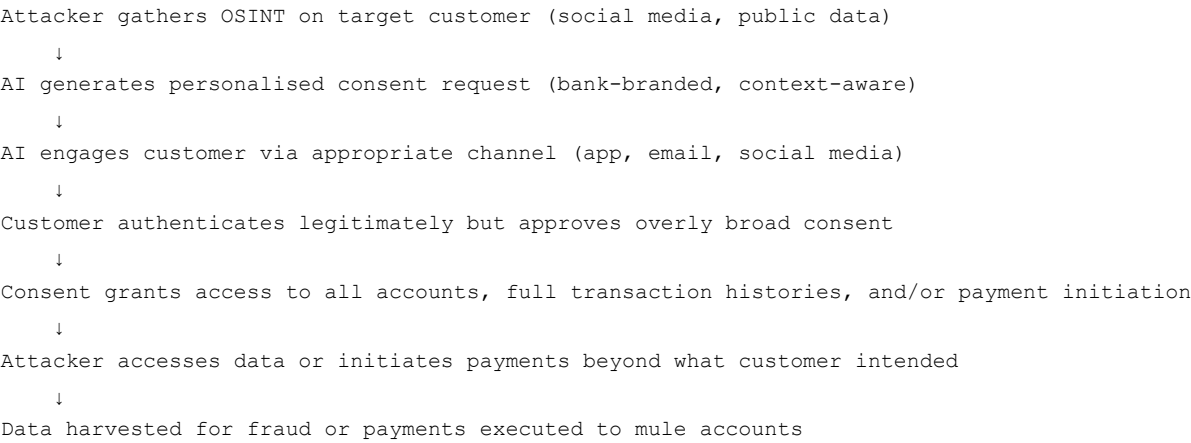
Dimension	Pre-GenAI	GenAI-Transformed
Consent deception	Manual social engineering	AI-generated personalised consent pages
Scale	Limited by human effort	Industrial-scale automated consent harvesting
Personalisation	Generic, detectable	Hyper-personalised based on OSINT
Adaptation	Static scripts	Real-time adaptation based on victim responses
Detection evasion	Obvious red flags	Indistinguishable from legitimate consent flows

HARD GenAI Removal Test result: PASS — GenAI enables personalised, adaptive, large-scale consent manipulation that materially disappears without it.

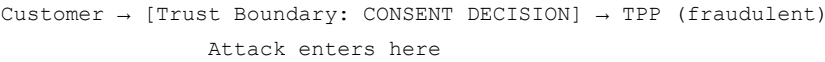
Prerequisites:

- Customer uses open banking / Account Aggregator framework
- Consent is obtained electronically
- Attacker can create convincing consent pages
- GenAI tools for personalisation and social engineering

Conceptual attack flow:



Trust boundary targeted:



The customer authenticates legitimately but the *consent decision itself* is manipulated. This is why the attack is Third-Party/Open Banking-primary, not Authentication.

Financial consequence:

- Data harvested for synthetic identity creation
- Unauthorised payments via PISP consent
- Targeted social engineering using financial profiles
- Direct financial loss to victims

C. Detection Intelligence

Signal Category	Observable Signal	Why It Matters	Detection Approach
Customer	Consent granted for unusually broad scopes	Indicates potential consent deception	Rules; Anomaly detection
Customer	Consent granted for data types inconsistent with user's normal activity	Indicates manipulated consent	ML (profile deviation)
Customer	Consent granted at unusual hours	Indicates automated/impersonal attack	Rules; Temporal anomaly
Customer	Rapid sequence of consents granted	Indicates automated consent harvesting	Velocity rules
TPP	New TPP with unusually high consent conversion rate	Indicates fraudulent TPP optimising for consent	ML anomaly detection
TPP	TPP requesting scopes inconsistent with declared service	Indicates scope creep/abuse	Rules; ML
Consent	Consent scope disproportionately broad for declared purpose	Indicates deception	Rules; ML
Consent	Consent revoked shortly after granting	Indicates victim realised deception	Rules
Permissions	Permissions used beyond declared purpose	Indicates scope abuse	Anomaly detection
API	Unusual API call patterns following consent	Indicates automated data harvesting	Sequence modeling
API	API calls to endpoints not needed for declared service	Indicates scope exploitation	Rules; Anomaly
Account	Access to accounts beyond what customer likely intended	Indicates consent deception	Anomaly detection
Account	Data extraction of full transaction histories	Indicates data harvesting	Rules; Anomaly
Transaction	Unusual payment amounts/beneficiaries following consent	Indicates PISP abuse	ML anomaly detection
Device/Session	Consent from unusual device/location	Indicates potential compromise	Rules; ML
Device/Session	Session anomalies during consent (rapid completion)	Indicates automated/bot behaviour	Behavioral biometrics
Behavioral	Unusual navigation during consent (searching, hesitation)	Indicates confusion/coercion	Behavioral analytics
Network	Same TPP with broad consents across multiple customers	Indicates coordinated consent harvesting	Graph Neural Network
Temporal	Consent-to-fraud time (short duration)	Indicates immediate exploitation	Temporal correlation

False Positives:

--

Legitimate Scenario	Why It Looks Similar	False-Positive Risk
Customer consolidating finances	Broad consent to financial aggregator	Blocking legitimate financial planning
Customer using new budgeting app	Consent to unfamiliar TPP	Blocking legitimate fintech adoption
Customer applying for loan	Broad consent for credit underwriting	Blocking legitimate credit access
Business integrating accounting software	Broad consent, frequent data access	Blocking legitimate business operations

Evasion Considerations (Defensive Threat Modeling):

Adaptive attackers might attempt to:

- **Personalise further** – use more detailed OSINT to make consent requests contextually perfect
- **Vary timing** – scatter consent harvesting across hours/days to avoid velocity alerts
- **Use legitimate-looking channels** – route consent requests through legitimate app store channels
- **Mimic legitimate TPP behaviour** – make API calls and data access look like legitimate financial management
- **Rotate TPP identities** – switch between multiple fraudulent TPPs to avoid pattern detection
- **Introduce noise** – include legitimate-looking API calls to obscure data harvesting

D. Simulation Intelligence

Component	Description	Classification
Synthetic customers	Victim personas with financial profiles, banking relationships, transaction histories	Algorithmic
Synthetic TPPs	Fraudulent TPP identities with consent harvesting capabilities	Algorithmic + Agentic
Legitimate applications	Known legitimate TPPs (budgeting apps, aggregators, lenders) for baseline	Algorithmic
Malicious applications	Fake TPPs with deceptive consent pages	Agentic
Consent records	Consent artefacts with scopes, durations, purposes	Algorithmic
Permissions	AISP scopes (balances, transactions, account details); PISP scopes (payment initiation)	Algorithmic
API calls	Consent requests, data access calls, payment initiation calls	Algorithmic + Agentic
Account data	Synthetic customer financial data (balances, transaction histories)	Algorithmic
Payment actions	PISP payment initiations following consent	Algorithmic
Transactions	Legitimate baseline transactions; fraudulent payments	Algorithmic
Devices/sessions	Device fingerprints, IP geolocation, session context	Algorithmic
Provider relationships	Customer-TPP relationships; consent histories	Algorithmic
Attack labels	Consent abuse, broad scope exploitation, consent deception	Algorithmic
Mutation parameters	Consent scope breadth, personalisation level, timing variation, channel variation	Algorithmic
Legitimate counterpart	Financial planning, credit underwriting, account aggregation, legitimate fintech adoption	Algorithmic
Edge cases	Partial success (some scopes granted, others not); consent revocation; multiple TPPs	Algorithmic

Simulation Type: **Agentic** (consent deception) + **Algorithmic** (consent parameters)

E. Evidence

Claim	Source	Publisher	Date	Evidence Type	Confidence	Maturity
Single consent system risks misuse; customers skip fine print	SBI MD Ashwini Kumar Tewari	SBI / News report	2025	Senior executive statement	VERIFIED	DEMONSTRATED
Fraudsters reaching out on very personal level using publicly available data	Kerry Thomas, SVP Fraud	Mastercard	2025	Industry leader statement	VERIFIED	DEMONSTRATED
Fraudsters themselves begin to leverage AI to generate new fraud patterns	Mastercard evidence	UK Parliament	2023	Primary source	VERIFIED	STRONG RESEARCH
GenAI enabling industrialised, personalised social engineering	FATF Horizon Scan	FATF	Dec 2025	Government report	VERIFIED	STRONG RESEARCH
Criminals increasingly exploiting GenAI and deepfakes to enable fraud	FATF	FATF	2025	Government report	VERIFIED	STRONG RESEARCH

FAMILY OB-002: MALICIOUS / FAKE TPP APPLICATIONS

A. Identity

Field	Value
Attack ID	OB-002
Attack Family	Malicious / Fake TPP Applications
Variants	Counterfeit fintech apps; Fake aggregators; Brand impersonation; Front business TPPs; App store fraud
Primary Lifecycle Stage	Third-Party / Open Banking (TPP Onboarding / Customer Acquisition)
Cross-stage Stages	Account Creation (data harvested for synthetic identities); Payment Initiation (PISP fraud); Authentication (credential theft)
Attacker	Fraudster; Organised crime ring; AI-powered fake app generator
Target	Open banking users; Customers of financial institutions; Users of fintech apps
Objective	Harvest financial data; Obtain payment consent; Steal credentials; Enable downstream fraud
Third-party Control Targeted	TPP-customer trust relationship; TPP onboarding; TPP reputation; Consent flow

B. Fraud Understanding

What is the attack?

Fraudsters create counterfeit third-party applications that appear legitimate to users, tricking them into sharing financial data or granting consent through open banking/Account Aggregator frameworks. The user trusts the application (believing it is a legitimate fintech) and grants consent to what is actually a fraudulent TPP.

Traditional mechanism:

Before GenAI, fake TPP applications were:

- Basic, detectable by poor quality (bad graphics, broken English, inconsistent branding)
- Limited in scale (each app required manual creation)
- Unable to maintain consistent professional branding

GenAI transformation:

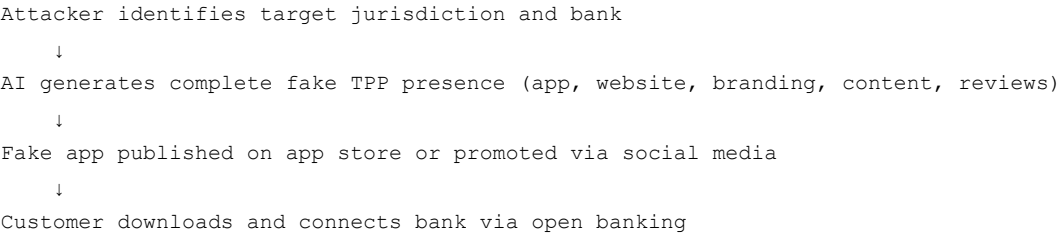
Dimension	Pre-GenAI	GenAI-Transformed
App quality	Basic, detectable	Professional-grade, indistinguishable from legitimate
Branding	Generic, inconsistent	Perfect brand impersonation
Content	Manual, limited	AI-generated product descriptions, support pages, reviews
Scale	Limited by manual effort	Industrial-scale fake app generation
Creation time	Weeks to months	Minutes to hours

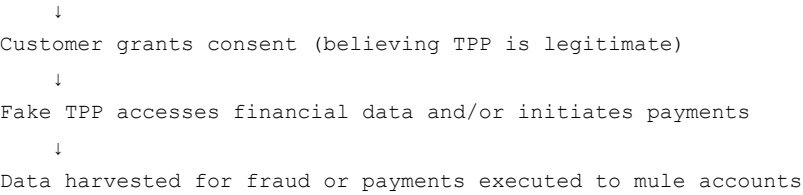
HARD GenAI Removal Test result: PASS – GenAI enables professional-grade fake TPPs at scale that materially disappear without it.

Prerequisites:

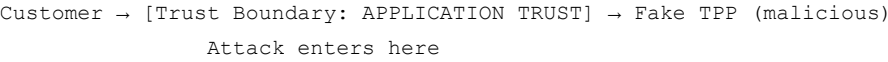
- Customer uses open banking / Account Aggregator framework
- Customer trusts app stores / fintech brands
- Attacker can create convincing fake apps
- GenAI tools for app generation

Conceptual attack flow:





Trust boundary targeted:



The customer trusts the application. The fake TPP is the attack vehicle; the consent mechanism is the attack vector.

Financial consequence:

- Data harvested for synthetic identity creation
- Unauthorised payments via PISP consent
- Credential theft (if app harvests login details)
- Direct financial loss to victims

C. Detection Intelligence

Signal Category	Observable Signal	Why It Matters	Detection Approach
Customer	Consent granted to previously unknown TPP	Indicates potential fake TPP engagement	Rules; Risk scoring
Customer	Consent granted to TPP with no digital footprint	Indicates potential fake TPP	Entity resolution
TPP	TPP has no established reputation	Potential fake TPP	Risk scoring; Threat intelligence
TPP	TPP website/app shows AI-generated artifacts	Indicates GenAI-created fake TPP	ML (CNN/Transformer/NLP)
TPP	TPP branding inconsistent with regulatory registration	Indicates impersonation	Entity resolution; Rules
TPP	TPP has unusually rapid customer acquisition	Indicates coordinated fake TPP campaign	Velocity rules; Anomaly
Consent	Consent granted to TPP with broad scopes	Potential data harvesting	Rules; ML
API	API calls from TPP with no prior legitimate relationship	Indicates potential fake TPP	Anomaly detection
Account	Data access by TPP with no legitimate purpose	Indicates data harvesting	Anomaly detection
Transaction	Payments to unusual beneficiaries from TPP users	Indicates fraud	ML anomaly detection
Network	Multiple customers granting consent to same suspicious TPP	Indicates fake TPP campaign	Graph Neural Network
Network	TPP connected to known fraud patterns	Indicates organised fraud	Threat intelligence

False Positives:

Legitimate Scenario	Why It Looks Similar	False-Positive Risk
New legitimate fintech launching	Unknown TPP, rapid customer acquisition	Blocking legitimate fintech innovation
Legitimate TPP with strong branding	Professional-grade app, "too perfect" design	False positives on professional design
Legitimate TPP expanding to new market	New jurisdiction, new customers	Blocking legitimate market expansion
Small fintech with limited history	No established reputation	Blocking legitimate startups

Evasion Considerations (Defensive Threat Modeling):

Adaptive attackers might attempt to:

- **Build digital footprint** – create convincing websites, social media presence, online reviews
- **Use legitimate app stores** – distribute fake apps through official channels
- **Establish positive history** – make legitimate-looking transactions to build reputation
- **Mimic legitimate TPP behaviour** – make API calls and consent patterns look normal
- **Rotate TPP identities** – switch between fake TPPs to avoid pattern detection

D. Simulation Intelligence

Component	Description	Classification
Synthetic customers	Customer personas who might download fake apps	Algorithmic
Synthetic TPPs	Complete fake TPP identities with branding, apps, websites, content	Agentic
Legitimate applications	Known legitimate TPPs for baseline	Algorithmic
Malicious applications	Fake TPPs with professional-grade appearance	Agentic
Consent records	Consent artefacts from fake TPP consent flows	Algorithmic
Permissions	Scopes requested by fake TPPs	Algorithmic
API calls	Consent requests, data access, payment initiation from fake TPPs	Algorithmic
Account data	Data accessed through fake TPPs	Algorithmic
Payment actions	Payments initiated through fake TPPs	Algorithmic
Transactions	Legitimate baseline; fraudulent payments via fake TPPs	Algorithmic
Devices/sessions	Device context for fake TPP usage	Algorithmic
Provider relationships	Customer-fake TPP relationships	Algorithmic
Attack labels	Fake TPP, counterfeit application, malicious fintech	Algorithmic
Mutation parameters	TPP quality, jurisdiction, channel, branding variation	Algorithmic
Legitimate counterpart	Legitimate fintech onboarding, new TPP adoption	Algorithmic
Edge cases	Partially legitimate TPPs; hybrid legitimate/fake	Algorithmic

Simulation Type: **Agentic** (fake TPP generation) + **Algorithmic** (parameters)

E. Evidence

Claim	Source	Publisher	Date	Evidence Type	Confidence	Maturity
Fraudsters create counterfeit third-party applications	UK Finance	UK Finance	2025	Industry body report	VERIFIED	STRONG RESEARCH
Fraudsters set up front business posing as fintech provider	UK Finance	UK Finance	2025	Industry body report	VERIFIED	STRONG RESEARCH
Fraudsters using AI to reach out on very personal level	Mastercard	Mastercard	2025	Industry leader statement	VERIFIED	DEMONSTRATED
Third-party impersonation is a key risk	Invela report	Invela	2025	Industry report	VERIFIED	STRONG RESEARCH

FAMILY OB-003: COMPROMISED TPP / API ENDPOINT

A. Identity

Field	Value
Attack ID	OB-003
Attack Family	Compromised TPP / API Endpoint
Variants	TPP credential theft; TPP API key compromise; Insider TPP compromise; Third-party breach; API endpoint exploitation
Primary Lifecycle Stage	Third-Party / Open Banking (TPP Operations / API Usage)
Cross-stage Stages	Payment Initiation (fraudulent payments via compromised TPP); Authentication (credential theft); AML/Compliance (mule activity)
Attacker	Cybercriminal; Organised fraud ring; External attacker; Insider
Target	TPP infrastructure; API endpoints; TPP credentials; Customer data
Objective	Use compromised TPP access to harvest customer data or initiate fraudulent payments
Third-party Control Targeted	TPP API credentials; Delegated access; Customer consents held by TPP; API trust relationship

B. Fraud Understanding

What is the attack?

Attackers compromise a legitimate TPP (through phishing, credential theft, or vulnerability exploitation) and use its credentials/API access to steal customer data or initiate fraudulent payments. A compromised TPP becomes a gateway to customer data at every bank it connects to.

Traditional mechanism:

Before GenAI, TPP compromise relied on:

- Manual phishing campaigns (generic, detectable)
- Manual vulnerability discovery (slow, limited)
- Static attack patterns

GenAI transformation:

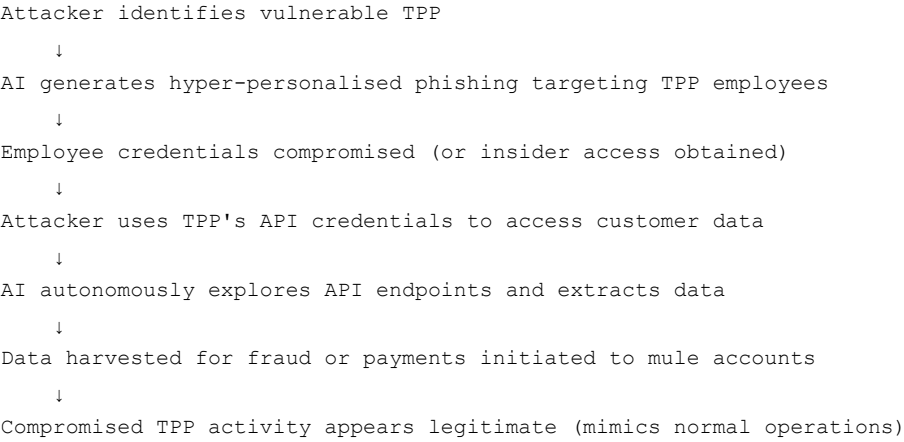
Dimension	Pre-GenAI	GenAI-Transformed
Credential theft	Manual phishing campaigns	AI-generated hyper-personalised phishing at scale
Vulnerability discovery	Manual probing	AI-powered automated vulnerability discovery
API abuse	Manual API calls	AI agents autonomously interact with TPP APIs
Detection evasion	Static patterns	Adaptive behaviour that mimics legitimate TPP activity
Scale	Limited	Industrial-scale credential harvesting and API abuse

HARD GenAI Removal Test result: PARTIAL — Attack exists without GenAI but GenAI materially amplifies credential theft, automation, and evasion.

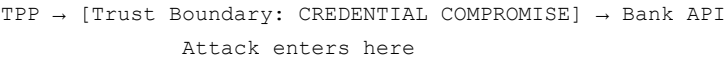
Prerequisites:

- TPP has API access to banks
- TPP has security vulnerabilities
- Attacker can compromise TPP credentials/API keys
- GenAI tools for phishing and vulnerability discovery

Conceptual attack flow:



Trust boundary targeted:



The attacker compromises TPP credentials or API keys, then uses the TPP's delegated access to fraudulently access customer data or initiate payments.

Financial consequence:

- Data breach (customer financial data exfiltrated)
- Unauthorised payments via compromised TPP
- Customer data sold on fraud marketplaces
- Reputational damage to TPP and banks

C. Detection Intelligence

Signal Category	Observable Signal	Why It Matters	Detection Approach
TPP	API keys used from unusual IP addresses	Indicates compromised credentials	Rules; Anomaly detection
TPP	API calls at unusual hours	Indicates automated/unauthorised use	Temporal anomaly
TPP	API call volume surges beyond normal range	Indicates data harvesting or system abuse	Anomaly detection
TPP	TPP accessing data it normally doesn't access	Indicates scope exploitation	Anomaly detection
TPP	TPP behaviour deviates from historical pattern	Indicates compromise	Behavioral analytics
TPP	TPP employee credential anomalies (login time, location)	Indicates credential theft	Rules; Anomaly
API	Rapid sequence of API calls	Indicates automated abuse	Velocity rules; Anomaly
API	API calls to unexpected endpoints	Indicates vulnerability exploitation	Rules; Anomaly
Account	Customer data accessed by TPP without business need	Indicates data harvesting	Anomaly detection
Transaction	Unusual payments via compromised TPP	Indicates fraud	ML anomaly detection
Network	Multiple TPPs showing similar compromise patterns	Indicates coordinated attack	Graph Neural Network
Temporal	Compromise-to-fraud time (short duration)	Indicates immediate exploitation	Temporal correlation

False Positives:

Legitimate Scenario	Why It Looks Similar	False-Positive Risk
TPP scaling operations	Increased API calls, new data access	Blocking legitimate business growth
TPP new product launch	New API endpoints, new data patterns	Blocking legitimate innovation
TPP employee working late	API calls at unusual hours	Blocking legitimate work patterns
TPP employee working remotely	API keys from new IP addresses	Blocking legitimate remote work

Evasion Considerations (Defensive Threat Modeling):

Adaptive attackers might attempt to:

- **Mimic TPP's normal behaviour** — make API calls at normal times, to normal endpoints
- **Gradually escalate** — start with low-volume data access and gradually increase
- **Rotate credentials** — use multiple compromised TPP credentials
- **Hide in noise** — mix legitimate and fraudulent API calls
- **Target TPP employees with least oversight** — focus on less-monitored roles

D. Simulation Intelligence

Component	Description	Classification
Synthetic customers	Customer personas whose data may be accessed	Algorithmic
Synthetic TPPs	Legitimate TPP profiles with API credentials, consent tokens	Algorithmic
Legitimate applications	TPPs with legitimate API usage patterns	Algorithmic
Malicious applications	Compromised TPPs used for fraud	Agentic
Consent records	Valid consents held by compromised TPPs	Algorithmic
Permissions	Scopes available to compromised TPPs	Algorithmic
API calls	API calls from compromised TPPs; fraudulent vs. legitimate mix	Algorithmic + Agentic
Account data	Data accessed through compromised TPPs	Algorithmic
Payment actions	Fraudulent payments via compromised TPPs	Algorithmic
Transactions	Legitimate baseline; fraudulent transactions	Algorithmic
Devices/sessions	API key usage context, IP addresses	Algorithmic
Provider relationships	TPP-customer relationships; compromise patterns	Algorithmic
Attack labels	Compromised TPP, API credential abuse, third-party breach	Algorithmic
Mutation parameters	Compromise method, data access patterns, payment patterns	Algorithmic
Legitimate counterpart	Legitimate TPP operations, business growth, new products	Algorithmic

Component	Description	Classification
Edge cases	Partial compromise; mixed legitimate/fraudulent activity	Algorithmic

Simulation Type: Hybrid (Agentic for compromised TPP operation + Algorithmic for parameters)

E. Evidence

Claim	Source	Publisher	Date	Evidence Type	Confidence	Maturity
Greater risk of API endpoints or TPPs being compromised	UK Finance	UK Finance	2025	Industry body report	VERIFIED	STRONG RESEARCH
Fraudsters target weakest links—TPPs may lack robust fraud awareness	UK Finance	UK Finance	2025	Industry body report	VERIFIED	STRONG RESEARCH
API-layer attacks surged 60%	Security industry	Security industry	2025	Industry data	VERIFIED	STRONG RESEARCH
57% of financial services firms reported API-related breaches	Datos Insights	Datos Insights	2025	Industry report	VERIFIED	STRONG RESEARCH
Fraudsters leverage AI to generate new fraud patterns	Mastercard	Mastercard	2023	Primary source	VERIFIED	STRONG RESEARCH

FAMILY OB-004: CONSENT / TOKEN THEFT AND REPLAY

A. Identity

Field	Value
Attack ID	OB-004
Attack Family	Consent / Token Theft and Replay
Variants	OAuth token theft; Refresh token abuse; Access token replay; Man-in-the-middle token interception; Credential replay
Primary Lifecycle Stage	Third-Party / Open Banking (API Authorisation / Token Usage)
Cross-stage Stages	Payment Initiation (fraudulent payments via stolen tokens); Authentication (token-based access); Account Creation (data access for synthetic identities)
Attacker	Fraudster; Man-in-the-middle; Credential harvester; Compromised TPP operator
Target	OAuth tokens; Consent tokens; Refresh tokens; API endpoints
Objective	Use stolen tokens to access customer data or initiate unauthorised payments
Third-party Control Targeted	OAuth token integrity; Consent token security; Access token lifespan; Sender-constrained tokens

B. Fraud Understanding

What is the attack?

Attackers steal OAuth consent tokens (access tokens, refresh tokens) through phishing, man-in-the-middle attacks, or credential harvesting, then replay them to access data or initiate payments. The bank API accepts the token as legitimate because it cannot distinguish the thief from the legitimate token holder.

Traditional mechanism:

Before GenAI, token theft relied on:

- Manual interception (MITM attacks, network sniffing)
- Generic phishing for OAuth tokens (detectable)
- Manual token testing (limited)

GenAI transformation:

Dimension	Pre-GenAI	GenAI-Transformed
Token harvesting	Manual phishing	AI-generated personalised token harvesting at scale
Token testing	Manual replay	AI agents autonomously test tokens across endpoints
Detection evasion	Static patterns	Adaptive token usage that mimics legitimate patterns

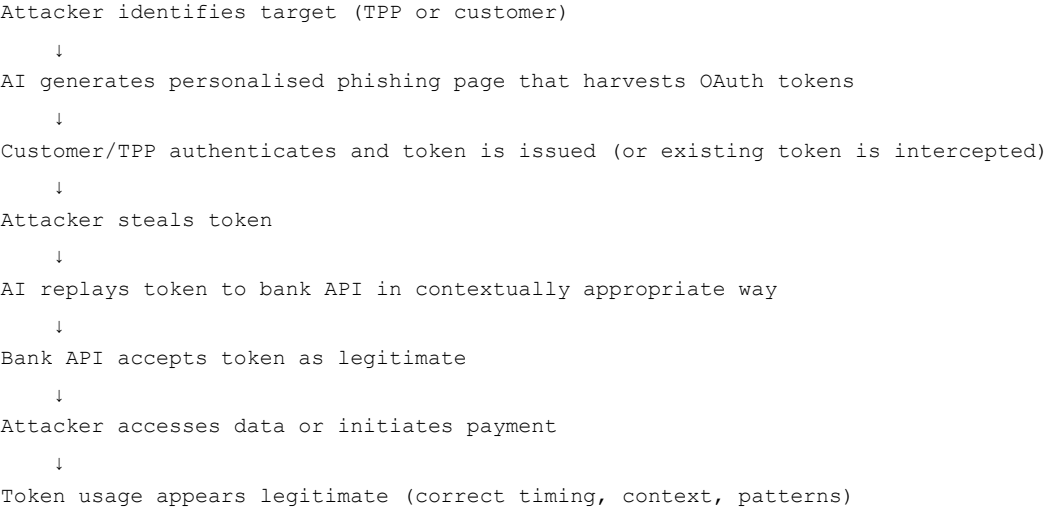
Dimension	Pre-GenAI	GenAI-Transformed
Scale	Limited	Industrial-scale token harvesting and testing

HARD GenAI Removal Test result: PARTIAL – Attack exists without GenAI but GenAI materially amplifies token harvesting, testing, and evasion.

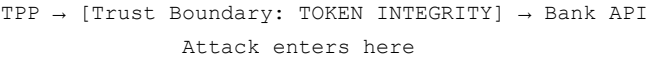
Prerequisites:

- Token theft vector (phishing, MITM, compromised device)
- Token not sender-constrained
- GenAI tools for personalised phishing

Conceptual attack flow:



Trust boundary targeted:



The token itself is the attack vector. The attacker steals a valid consent token and replays it to the bank API.

Financial consequence:

- Unauthorised data access
- Unauthorised payments via stolen tokens
- Customer data exfiltrated
- Direct financial loss

C. Detection Intelligence

Signal Category	Observable Signal	Why It Matters	Detection Approach
API	Token used from unusual IP address	Indicates token theft	Rules; Anomaly
API	Token used at unusual times	Indicates automated/unauthorised use	Temporal anomaly
API	Token used for scopes beyond normal	Indicates scope abuse	Rules; ML
API	Token used to access data not normally accessed	Indicates data harvesting	Anomaly
API	Rapid sequence of token usage	Indicates automated replay	Velocity rules
API	Token usage patterns deviate from baseline	Indicates compromise	Behavioral analytics
Token	Token used after expiry or before issued	Indicates token manipulation	Rules
Token	Token used multiple times (replay)	Indicates replay attack	Idempotency tracking
Account	Customer data accessed by token with no business need	Indicates token abuse	Anomaly detection
Transaction	Unusual transactions via stolen token	Indicates fraud	ML anomaly detection
Network	Multiple tokens showing similar abuse patterns	Indicates coordinated token theft	Graph Neural Network

False Positives:

Legitimate Scenario	Why It Looks Similar	False-Positive Risk
Customer using multiple devices	Token used from different IPs	Blocking legitimate multi-device usage
TPP legitimate token refresh	Token usage pattern changes	Blocking legitimate token lifecycle
Customer travelling	Token used from unusual location	Blocking legitimate travel

Evasion Considerations (Defensive Threat Modeling):

Adaptive attackers might attempt to:

- **Use tokens in contextually appropriate ways** – match legitimate timing, locations, and patterns
- **Rotate tokens** – use multiple stolen tokens to avoid pattern detection
- **Mimic legitimate TPP behaviour** – make token usage look like normal TPP operations
- **Use tokens during normal business hours** – avoid off-hours flagging

D. Simulation Intelligence

Component	Description	Classification
Synthetic customers	Customer personas with consent tokens	Algorithmic
Synthetic TPPs	TPPs with valid tokens	Algorithmic
Consent records	Tokens with scopes, durations, contexts	Algorithmic
Permissions	Scopes available via stolen tokens	Algorithmic
API calls	Token usage patterns; legitimate vs. stolen	Algorithmic + Agentic
Account data	Data accessed via stolen tokens	Algorithmic
Payment actions	Payments initiated via stolen tokens	Algorithmic
Transactions	Legitimate baseline; fraudulent via stolen tokens	Algorithmic
Devices/sessions	Token usage context	Algorithmic
Attack labels	Token theft, token replay, credential theft	Algorithmic
Mutation parameters	Token type, usage pattern, timing variation	Algorithmic
Legitimate counterpart	Legitimate token usage, multi-device usage	Algorithmic
Edge cases	Partial token theft; mixed legitimate/fraudulent	Algorithmic

Simulation Type: Hybrid (Agentic for token harvesting + Algorithmic for token usage parameters)

E. Evidence

Claim	Source	Publisher	Date	Evidence Type	Confidence	Maturity
Insecure OAuth implementations and token misuse can produce high-impact breaches	Security research	Security research	2025	Technical analysis	VERIFIED	STRONG RESEARCH
Attackers target payment systems by manipulating authentication tokens	Security research	Security research	2025	Security research	VERIFIED	STRONG RESEARCH
Token harvesting and credential replay are documented threats	Security research	Security research	2025	Security research	VERIFIED	STRONG RESEARCH

FAMILY OB-005: DELEGATED ACCESS / SCOPE ABUSE

A. Identity

Field	Value
Attack ID	OB-005
Attack Family	Delegated Access / Scope Abuse
Variants	Scope creep; Permission misuse; Broad scope exploitation; Unauthorised data access; Permission escalation
Primary Lifecycle Stage	Third-Party / Open Banking (Consent Scope Enforcement)

Field	Value
Cross-stage Stages	Account Creation (data harvested for synthetic identities); Payment Initiation (scope enables PISP abuse); AML/Compliance (data for fraud profiling)
Attacker	Malicious TPP; Compromised TPP; Insider; Fraudster
Target	Consent scope boundaries; Permission models; Customer data
Objective	Use legitimate permissions beyond their intended scope to harvest data or initiate payments
Third-party Control Targeted	Consent scope boundaries; Permission model; Delegated authority; Least-privilege controls

B. Fraud Understanding

What is the attack?

Attackers exploit overly broad consent scopes to access data or initiate payments beyond what the customer intended. A token issued for one consented action can silently unlock unrelated balances or payment capabilities. Broad scopes collapse least-privilege controls and make it harder to prove what a TPP actually accessed.

Traditional mechanism:

Before GenAI, scope abuse relied on:

- Manual exploitation of broad scopes (limited discovery)
- Static data extraction patterns (detectable)

GenAI transformation:

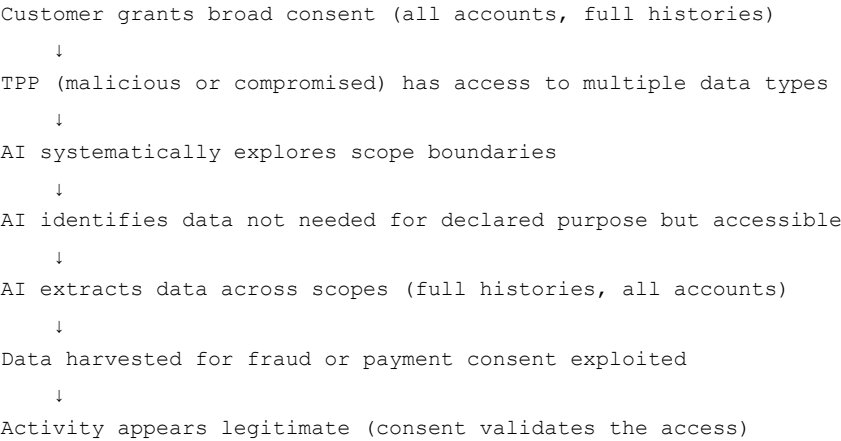
Dimension	Pre-GenAI	GenAI-Transformed
Scope discovery	Manual probing	AI-powered automated scope exploration
Data extraction	Manual data access	AI agents systematically extract data across scopes
Detection evasion	Static patterns	Adaptive access that mimics legitimate TPP behaviour
Scale	Limited	Industrial-scale scope exploitation

HARD GenAI Removal Test result: PARTIAL – Attack exists without GenAI but GenAI materially amplifies scope discovery, extraction, and evasion.

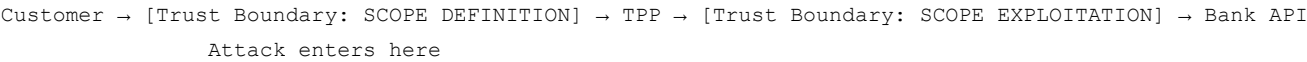
Prerequisites:

- Customer granted broad consent
- TPP has access to multiple scopes
- Scope enforcement is weak
- GenAI tools for scope exploration and data extraction

Conceptual attack flow:



Trust boundary targeted:



The attack exploits the gap between what the customer *intended* and what the consent *permits*. The customer's intent is the vulnerability.

Financial consequence:

- Data harvested for synthetic identity creation
- Unauthorised payments via PISP consent
- Targeted social engineering using financial profiles
- Privacy violations

C. Detection Intelligence

Signal Category	Observable Signal	Why It Matters	Detection Approach
Consent	Consent scope disproportionately broad for declared purpose	Indicates potential scope abuse	Rules; ML
Consent	Consent includes data types not needed for declared service	Indicates potential deception	Rules; ML
API	API calls to endpoints beyond those needed for declared service	Indicates scope exploitation	Anomaly detection
API	Data access patterns inconsistent with declared purpose	Indicates scope abuse	ML
Permission	Scopes used beyond what customer likely intended	Indicates scope exploitation	Anomaly detection
Permission	Access to data not needed for declared service	Indicates scope abuse	Rules; ML
Account	Access to accounts beyond those needed for declared service	Indicates scope exploitation	Anomaly detection
Data	Requests for full transaction histories when only balances needed	Indicates data harvesting	Rules; ML
Data	Requests for all accounts when only specific accounts needed	Indicates scope abuse	Rules; ML
Behavioral	TPP data access patterns inconsistent with its business purpose	Indicates scope exploitation	Anomaly detection
Network	Multiple TPPs showing similar scope abuse patterns	Indicates coordinated exploitation	Graph Neural Network

False Positives:

Legitimate Scenario	Why It Looks Similar	False-Positive Risk
Financial planning app	Broad data access (all accounts, full history)	Blocking legitimate financial planning
Credit underwriting	Broad data access (income, employment, accounts)	Blocking legitimate credit access
Wealth management	Broad data access (investment accounts, balances)	Blocking legitimate wealth management
Business accounting	Broad data access (business accounts, transactions)	Blocking legitimate business operations

Evasion Considerations (Defensive Threat Modeling):

Adaptive attackers might attempt to:

- **Request gradually broader scopes** – start with minimal scopes, request more over time
- **Justify broad scopes** – create plausible business reasons for broad data access
- **Mix legitimate and abusive access** – make scope exploitation look like normal operations
- **Target customers with low financial literacy** – less likely to question broad consents

D. Simulation Intelligence

Component	Description	Classification
Synthetic customers	Customer personas with consent histories	Algorithmic
Synthetic TPPs	TPPs with declared purposes and actual access patterns	Algorithmic
Consent records	Consent artefacts with scopes, purposes	Algorithmic
Permissions	Scopes granted vs. scopes actually used	Algorithmic
API calls	Data access patterns; legitimate vs. abusive	Algorithmic + Agentic
Account data	Data accessed vs. data needed	Algorithmic
Transactions	Legitimate baseline; abusive access patterns	Algorithmic
Attack labels	Scope abuse, delegated access abuse, permission misuse	Algorithmic
Mutation parameters	Scope breadth, data type, access pattern	Algorithmic
Legitimate counterpart	Legitimate broad-scope usage (financial planning, credit)	Algorithmic
Edge cases	Partially abusive access; scope creep	Algorithmic

Simulation Type: Hybrid (Agentic for scope exploitation + Algorithmic for scope parameters)

E. Evidence

Claim	Source	Publisher	Date	Evidence Type	Confidence	Maturity
Broad scopes collapse least-privilege controls; increase blast radius of compromised token	Security research	Security research	2026	Technical analysis	VERIFIED	STRONG RESEARCH
Delegated access becomes riskier when access is broad, hard to revoke, or poorly audited	Security research	Security research	2026	Technical analysis	VERIFIED	STRONG RESEARCH
Scope creep is a documented problem in open banking	Security research	Security research	2025	Industry analysis	VERIFIED	STRONG RESEARCH

FAMILY OB-006: ACCOUNT INFORMATION HARVESTING

A. Identity

Field	Value
Attack ID	OB-006
Attack Family	Account Information Harvesting
Variants	Financial data harvesting; Transaction history exfiltration; Balance monitoring; Account aggregation abuse; Financial profiling
Primary Lifecycle Stage	Third-Party / Open Banking (AISP Data Access)
Cross-stage Stages	Account Creation (data for synthetic identities); Authentication (data for social engineering); AML/Compliance (data for fraud profiling)
Attacker	Malicious TPP; Compromised TPP; Data broker; Organised fraud ring
Target	AISP data access; Customer financial information
Objective	Harvest detailed financial profiles for targeted social engineering, synthetic identity creation, or sale
Third-party Control Targeted	AISP data access; Financial data privacy; Data extraction patterns; Data exfiltration

B. Fraud Understanding

What is the attack?

Malicious or compromised TPPs use AISP data access to systematically harvest detailed financial profiles—balances, transactions, account details—for sale or downstream fraud. Open banking data provides a detailed understanding of an individual's financial vulnerability, making it extremely valuable for fraudsters.

Traditional mechanism:

Before GenAI, data harvesting relied on:

- Manual data extraction (limited scale)
- Static extraction patterns (detectable)

GenAI transformation:

Dimension	Pre-GenAI	GenAI-Transformed
Data extraction	Manual	AI agents systematically extract data at scale
Data analysis	Manual review	AI-powered financial profiling and analysis
Detection evasion	Static patterns	Adaptive access that mimics legitimate AISP behaviour
Scale	Limited	Industrial-scale data harvesting

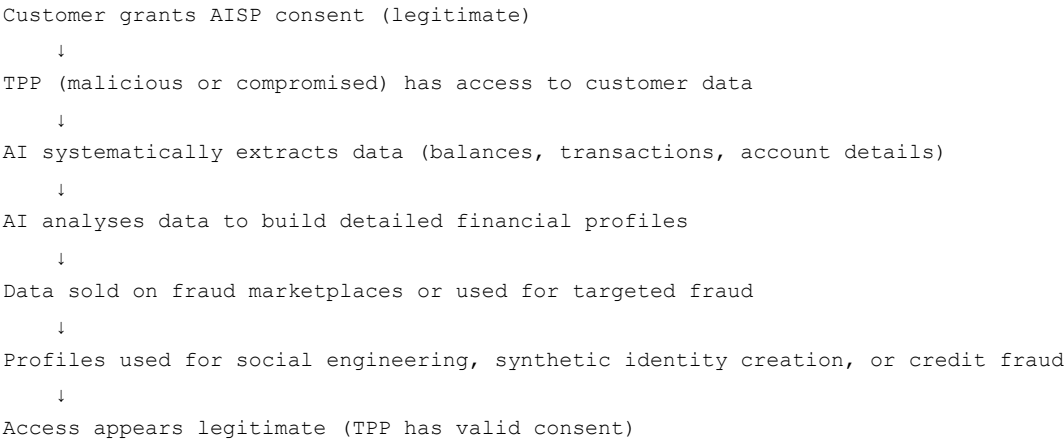
HARD GenAI Removal Test result: PARTIAL — Attack exists without GenAI but GenAI materially amplifies extraction, analysis, and evasion.

Prerequisites:

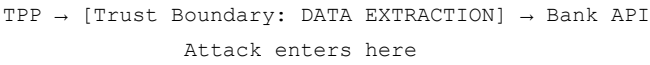
- AISP access granted
- TPP has access to customer data

- TPP can extract and exfiltrate data
- GenAI tools for data extraction and analysis

Conceptual attack flow:



Trust boundary targeted:



The attack exploits AISP data access to systematically extract and exfiltrate customer financial data. The consent is valid; the abuse is in the *volume and use* of the data.

Financial consequence:

- Data sold on fraud marketplaces
- Targeted social engineering using financial profiles
- Synthetic identity creation
- Credit fraud using harvested data

C. Detection Intelligence

Signal Category	Observable Signal	Why It Matters	Detection Approach
API	High volume of data access calls	Indicates systematic harvesting	Anomaly detection; Velocity rules
API	Data access at unusual hours	Indicates automated extraction	Temporal anomaly
API	Access to full transaction histories	Indicates data harvesting	Rules; ML
API	Access to all accounts (not just specific ones)	Indicates systematic harvesting	Rules; ML
API	Repeated data access (same data multiple times)	Indicates data exfiltration	Anomaly detection
Account	Data extracted for accounts with no business need	Indicates harvesting	Anomaly detection
Data	Transaction history requests beyond business need	Indicates data harvesting	Rules; ML
Data	Balance requests at unusual frequency	Indicates systematic monitoring	Velocity rules
TPP	TPP data access inconsistent with its business purpose	Indicates potential harvesting	Risk scoring; ML
TPP	TPP with no legitimate need for broad data access	Indicates malicious TPP	Rules; Risk scoring
Network	Multiple TPPs showing similar data harvesting patterns	Indicates coordinated campaign	Graph Neural Network

False Positives:

Legitimate Scenario	Why It Looks Similar	False-Positive Risk
Financial planning app	Full transaction history, all accounts	Blocking legitimate financial planning
Credit underwriting	Full transaction history, income verification	Blocking legitimate credit access
Wealth management	Investment account data, balances	Blocking legitimate wealth management
Accounting software	Business transaction history, all accounts	Blocking legitimate business operations
Tax preparation	Full financial data for tax filing	Blocking legitimate tax preparation

Evasion Considerations (Defensive Threat Modeling):

Adaptive attackers might attempt to:

- **Spread extraction over time** — avoid high-volume alerts by gradually extracting data
- **Mix legitimate and harvesting requests** — hide harvesting in legitimate operations
- **Target specific data types** — prioritise the most valuable data to minimise extraction volume
- **Justify data access** — create plausible business reasons for data extraction
- **Use multiple TPPs** — distribute harvesting across multiple TPPs

D. Simulation Intelligence

Component	Description	Classification
Synthetic customers	Customer personas with financial profiles	Algorithmic
Synthetic TPPs	AISP TPPs with declared purposes	Algorithmic
Legitimate applications	Financial planning, credit, accounting, wealth management	Algorithmic
Malicious applications	TPPs that harvest data	Agentic
Consent records	AISP consent artefacts	Algorithmic
Permissions	AISP scopes for data access	Algorithmic
API calls	Data access patterns; legitimate vs. harvesting	Algorithmic + Agentic
Account data	Balances, transactions, account details	Algorithmic
Transactions	Legitimate baseline; no payment (data access only)	Algorithmic
Devices/sessions	Data access context	Algorithmic
Provider relationships	TPP-customer data access relationships	Algorithmic
Attack labels	Data harvesting, financial profiling, AISP abuse	Algorithmic
Mutation parameters	Data type, access volume, timing	Algorithmic
Legitimate counterpart	Legitimate financial planning, credit, accounting	Algorithmic
Edge cases	Partial harvesting; mixed legitimate/harvesting	Algorithmic

Simulation Type: Hybrid (Agentic for data extraction + Algorithmic for data parameters)

E. Evidence

Claim	Source	Publisher	Date	Evidence Type	Confidence	Maturity
Open banking data provides detailed understanding of financial vulnerability	Academic research	Academic	2025	Academic study	VERIFIED	STRONG RESEARCH
Widespread integration of third-party apps has increased fraud incidents	Academic research	Academic	2025	Academic study	VERIFIED	STRONG RESEARCH
Phishing, credential misuse, and unauthorized access are documented threats	Academic research	Academic	2025	Academic study	VERIFIED	STRONG RESEARCH

PART 4 – COVERAGE AUDIT

Third-party/Open Banking Surface	Considered?	Covered By	Separate Family?	Decision	Reason
Consent abuse	✓	OB-001	Yes	KEEP	GenAI enables personalised, adaptive, large-scale consent manipulation
Delegated-access abuse	✓	OB-005	Yes	KEEP	Scope boundaries are the attack surface
Excessive permissions	✓	OB-005	No (variant)	MERGE → OB-005	Same underlying mechanism as scope abuse
Malicious TPP	✓	OB-002	Yes	KEEP	Fake TPP is the attack vehicle
Fake TPP	✓	OB-002	Yes	KEEP	TPP-customer trust relationship exploited

Third-party/Open Banking Surface	Considered?	Covered By	Separate Family?	Decision	Reason
TPP impersonation	✓	—	—	MOVE → Authentication	Credential theft is primary mechanism
Compromised TPP	✓	OB-003	Yes	KEEP	TPP delegated access and API trust exploited
API credential abuse	✓	OB-003	No (variant)	MERGE → OB-003	Same underlying mechanism as compromised TPP
API manipulation	✓	—	—	MOVE → Gateway/Processor / Payment Initiation	API parameter manipulation is primary (GP-001/PI-F001)
Authorization-token abuse	✓	OB-004	Yes	KEEP	OAuth token integrity is the attack surface
Financial-data harvesting	✓	OB-006	Yes	KEEP	AISP data access is the attack surface
Payment-initiation abuse through TPP	✓	—	—	MOVE → Payment Initiation	Payment Initiation is primary; TPP relationship is incidental
Cross-provider abuse	✓	—	—	MOVE → Cross-Stage / Network-Level	Spans multiple TPPs, banks, jurisdictions
Malicious fintech application	✓	OB-002	No (variant)	MERGE → OB-002	Same underlying mechanism as fake TPP
Adaptive third-party abuse	✓	OB-001, OB-003, OB-005	No (capability)	MERGE	GenAI capability across multiple families
Agentic TPP interaction	✓	OB-001, OB-002	No (capability)	MERGE	GenAI capability across multiple families
APP fraud via open banking	✓	—	—	MOVE → Payment Initiation (PI-F002)	APP fraud is primary; open banking is channel
Consent revocation abuse	✓	OB-001	No (variant)	MERGE → OB-001	Same underlying mechanism as consent abuse
Consent duration abuse	✓	OB-001	No (variant)	MERGE → OB-001	Same underlying mechanism as consent abuse
Refresh token abuse	✓	OB-004	No (variant)	MERGE → OB-004	Same underlying mechanism as token theft
Synthetic TPP identity	✓	OB-002	No (variant)	MERGE → OB-002	Same underlying mechanism as fake TPP
TPP insider abuse	✓	OB-003	No (variant)	MERGE → OB-003	Same underlying mechanism as compromised TPP
TPP supply chain compromise	—	—	—	THEORETICAL	Insufficient evidence; future threat
AI-agent autonomous consent fraud	✓	—	—	MOVE → AI-Agent Commerce	Agent autonomy is primary if agent exploits consent

Excluded Candidates – Detailed Rationale

Candidate	Decision	Rationale
API Parameter Manipulation	MOVE → Gateway/Processor (GP-001) / Payment Initiation (PI-F001)	Primary mechanism is API parameter manipulation. TPP relationship is incidental. Already covered in Gateway/Processor and Payment Initiation taxonomies.
APP Fraud via Open Banking	MOVE → Payment Initiation (PI-F002)	Primary mechanism is APP fraud. Open banking is the channel, not the defining mechanism. Already covered in Payment Initiation taxonomy.
TPP/Bank Impersonation	MOVE → Authentication	Primary mechanism is credential theft. Authentication is the attack surface. Already covered in Authentication taxonomy (AUTH-001, AUTH-002, AUTH-003).
Cross-Provider/Cross-Border Exploitation	MOVE → Cross-Stage / Network-Level	Spans multiple TPPs, banks, and jurisdictions. Not a single Third-Party/Open Banking attack. Belongs to Cross-Stage category.
AI-Agent Automated Consent Fraud	MOVE → AI-Agent Commerce	If an AI agent autonomously exploits consent, the agent's autonomy is primary. Already covered in AI-Agent Commerce taxonomy (AG-001, AG-002, AG-005).
Generic API Injection	DROP	Not payment fraud-specific. Belongs to general API security or Gateway/Processor.
TPP Supply Chain Compromise	THEORETICAL	Plausible but insufficient real-world evidence. Track as future threat.

PART 5 – PRODUCT MAPPING

RED TEAM – What the Attacker/Simulator Generates

Generated Element	Description	Method
Synthetic TPP identities	Complete fake TPP profiles with branding, apps, websites, content	Agentic (GenAI)
Synthetic customers	Victim personas with financial profiles, banking relationships, social media presence	Algorithmic
Consent records	Consent artefacts with varying scopes, durations, purposes	Algorithmic
Consent deception pages	AI-generated, bank-branded, personalised consent pages	Agentic (GenAI)
Token usage patterns	API call sequences with tokens from different contexts	Algorithmic + Agentic
Data access patterns	AISP data extraction sequences (balances, transactions, account details)	Algorithmic + Agentic
Compromised TPP activity	API call patterns from compromised credentials	Agentic
TPP transaction histories	Legitimate baseline transactions; fraudulent payments	Algorithmic
Attack labels	Consent abuse, fake TPP, compromised TPP, token theft, scope abuse, data harvesting	Algorithmic
Mutation parameters	Scope breadth, personalisation level, timing variation, channel variation	Algorithmic

GENERATE – What is Algorithmic vs Agentic

Component	Classification	Description
Synthetic customers	Algorithmic	Parameterised personas with demographics, financial profiles, banking relationships
Synthetic TPPs	Algorithmic + Agentic	Basic TPP profiles algorithmic; full fake TPP presence agentic
Consent deception	Agentic	AI-generated personalised consent pages and social engineering scripts
Token usage	Algorithmic	Parameterised token usage patterns based on legitimate and malicious behaviour
Data access	Algorithmic + Agentic	Algorithmic parameters; agentic for systematic extraction and evasion
Compromised TPP activity	Agentic	AI-automated API abuse through compromised TPP credentials
API call patterns	Algorithmic	Parameterised sequences based on TPP type and purpose
Network relationships	Algorithmic	Parameterised TPP-customer relationships and network structures
Mutation	Algorithmic	Parameterised variation of attack dimensions

DEFEND – What the Blue Team Detects

Detection Area	What to Detect	Method
TPP behaviour	TPP behaviour deviation from historical baseline; API usage anomalies	Anomaly detection; Behavioral analytics; Risk scoring
Consent anomalies	Consents with unusually broad scopes; consents inconsistent with declared purpose; rapid consent sequences	Rules; Supervised ML; Anomaly detection
Permission/scope abuse	Permissions used beyond declared purpose; data access inconsistent with business need	Rules; ML classification; Anomaly detection
API call patterns	High-volume data access; unusual API call timing; unexpected endpoint access	Rules; Anomaly detection; Sequence modeling
Token anomalies	Token used from unusual context; token usage pattern deviation; token replay	Rules; Anomaly detection; Idempotency tracking
Account/data access	Access to accounts/data not needed for declared purpose; systematic data extraction	Rules; ML; Anomaly detection
Transaction anomalies	Unusual payment amounts/beneficiaries following TPP interaction	ML anomaly detection; Graph Neural Network
Graph relationships	TPP connected to multiple broad consents; customers with similar consent patterns to same TPP	Graph Neural Network; Clustering
Temporal patterns	Consent-to-fraud time; unusual timing; rapid sequences	Temporal correlation; Velocity rules

Detection Area	What to Detect	Method
Behavioral patterns	Unusual navigation during consent; signs of coercion/hesitation	Behavioral biometrics; Voice stress analysis

FEEDBACK – How the Closed Loop Works

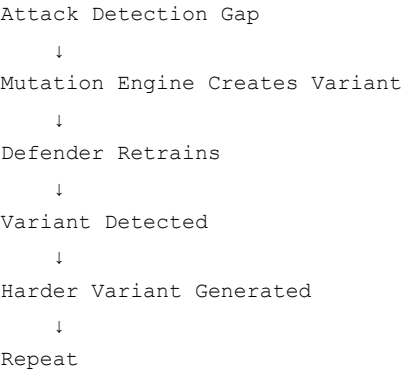
Weakness Discovery:

- 1. Defender fails to detect a generated Third-Party/Open Banking attack
- 2. System records the evasion pattern (which signals were bypassed)
- 3. Generate module creates variants that exploit the same blind spot:
 - Adjust personalisation level
 - Modify consent scope patterns
 - Change timing/distribution
 - Rotate TPP identities
- 4. Defender retrains on the new variants
- 5. Harder variants are generated until detection is reliable

Attack Hypothesis Generation:

- 1. Defender identifies a new evasion pattern (e.g., fake TPPs using authentic-looking app store presence)
- 2. Pattern is codified as a new mutation parameter
- 3. Generate module incorporates the parameter into mutation space
- 4. New variants are generated to test the defender
- 5. Cycle repeats

Detection Hardening:



PART 6 – FINAL SUMMARY

Table 1 – FINAL THIRD-PARTY / OPEN BANKING TAXONOMY

ID	Attack Family	Variants	GenAI Classification	Simulation Type	Primary Stage	Control Targeted	Reason for Distinctness
OB-001	Consent Abuse / Broad Consent Exploitation	Single consent exploitation; Broad scope abuse; Consent deception; Fine-print exploitation; Consent phishing	PASS	Agentic	Consent Granting	Consent scope; Customer consent decision	GenAI enables personalised, adaptive, large-scale consent manipulation that materially disappears without it
OB-002	Malicious / Fake TPP Applications	Counterfeit fintech apps; Fake aggregators; Brand impersonation; Front business TPPs	PASS	Agentic	TPP Onboarding / Customer Acquisition	TPP-customer trust relationship; TPP onboarding	GenAI enables professional-grade fake TPPs at scale that materially disappear without it
OB-003	Compromised TPP / API Endpoint	TPP credential theft; TPP API key compromise; Insider TPP compromise; Third-party breach	PARTIAL	Hybrid	TPP Operations / API Usage	TPP API credentials; Delegated access	Attack exists without GenAI but GenAI materially amplifies credential theft, automation, and evasion

ID	Attack Family	Variants	GenAI Classification	Simulation Type	Primary Stage	Control Targeted	Reason for Distinctness
OB-004	Consent / Token Theft and Replay	OAuth token theft; Refresh token abuse; Access token replay; MITM token interception	PARTIAL	Hybrid	API Authorisation / Token Usage	OAuth token integrity; Consent token security	Attack exists without GenAI but GenAI materially amplifies token harvesting, testing, and evasion
OB-005	Delegated Access / Scope Abuse	Scope creep; Permission misuse; Broad scope exploitation; Unauthorised data access	PARTIAL	Hybrid	Consent Scope Enforcement	Consent scope boundaries; Permission model	Attack exists without GenAI but GenAI materially amplifies scope discovery, extraction, and evasion
OB-006	Account Information Harvesting	Financial data harvesting; Transaction history exfiltration; Balance monitoring; Financial profiling	PARTIAL	Hybrid	AISP Data Access	AISP data access; Financial data privacy	Attack exists without GenAI but GenAI materially amplifies extraction, analysis, and evasion

Table 2 – ATTACK × OBSERVABLE SIGNAL

Attack Family	TPP	Consent	Permission	API	Account	Transaction	Device	Behavioral	Network	Temporal
OB-001: Consent Abuse	New TPP; High conversion rate	Broad scopes; Rapid sequences; Revocation	Scope-pattern mismatch	Unusual call patterns	Access beyond intent	Unusual payments post-consent	Unusual device; Session anomalies	Hesitation; Confusion signs	Same TPP; Multiple victims	Off-hours; Rapid sequences
OB-002: Fake TPP	Unknown TPP; No reputation; AI-generated content	Consents to unknown TPPs	Broad scopes requested	API from unknown TPP	Data access by unknown TPP	Unusual payments from TPP users	App installation context	Unusual adoption patterns	Multiple victims; Connected fraud	Rapid customer acquisition
OB-003: Compromised TPP	Behaviour deviation; Credential anomalies	Consents used unusually	Scopes used unusually	Unusual IP; Timing; Volume	Data not normally accessed	Unusual payments via TPP	API key context	Operation pattern change	Similar compromise patterns	Compromise-to-fraud time
OB-004: Token Theft	N/A (token-level)	Token usage deviation	Scopes beyond normal	Token from unusual context; Replay	Data via stolen token	Transactions via stolen token	Token usage context	Token pattern deviation	Multiple token abuse patterns	Unusual token timing
OB-005: Scope Abuse	Purpose-activity mismatch	Scope inconsistent with purpose	Scopes beyond need	Endpoints beyond need	Data beyond need	Payments enabled by broad scope	N/A	Data pattern deviation	Multiple scope abuse patterns	Scope-to-abuse time
OB-006: Data Harvesting	Purpose-activity mismatch	Broad AISP consents	Access beyond need	High-volume data access; Repeated	Full histories; All accounts	N/A (data only)	Access context	Extraction patterns	Similar harvesting patterns	Unusual extraction timing

Table 3 – ATTACK × SIMULATION

Attack Family	Synthetic Customers	Synthetic TPPs	Synthetic Apps	Synthetic Consents	Synthetic Permissions	Synthetic API Events	Synthetic Transactions	Synthetic Network	Simulation Type
OB-001: Consent Abuse	Victim personas; Financial profiles	Fraudulent TPP identities	Deceptive consent pages	Scopes; Durations; Purposes	AISP/PISP scopes	Consent requests; Data calls	Legitimate baseline; Fraudulent payments	Customer-TPP relationships	Agentic
OB-002: Fake TPP	Customer personas	Complete fake TPP identities	Fake apps; Websites; Branding	Consent artefacts	Scopes requested	Consent requests; Data access	Legitimate baseline; Fraudulent payments	Customer-TPP relationships	Agentic
OB-003: Compromised TPP	Customer personas	Legitimate TPP profiles	Legitimate applications	Valid consents	Available scopes	API calls; Fraudulent mix	Legitimate baseline; Fraudulent transactions	Compromise patterns	Hybrid

Attack Family	Synthetic Customers	Synthetic TPPs	Synthetic Apps	Synthetic Consents	Synthetic Permissions	Synthetic API Events	Synthetic Transactions	Synthetic Network	Simulation Type
OB-004: Token Theft	Customer personas	TPPs with valid tokens	N/A	Tokens; Scopes; Contexts	Scopes available	Token usage patterns	Legitimate baseline; Fraudulent transactions	Token abuse patterns	Hybrid
OB-005: Scope Abuse	Customer personas	TPPs with declared purposes	Legitimate applications	Scopes; Purposes	Granted vs. used scopes	Data access patterns	Legitimate baseline	Scope exploitation patterns	Hybrid
OB-006: Data Harvesting	Customer personas	AISP TPPs	Financial apps	AISP consents	AISP scopes	Data extraction patterns	N/A (data only)	Harvesting patterns	Hybrid

Table 4 – TAXONOMY DECISIONS

Candidate	Decision	Reason
Consent Abuse	KEEP (OB-001)	PASS; GenAI enables personalised, adaptive, large-scale consent manipulation
Fake TPP Applications	KEEP (OB-002)	PASS; GenAI enables professional-grade fake TPPs at scale
Compromised TPP	KEEP (OB-003)	PARTIAL; attack exists but GenAI materially amplifies credential theft, automation, and evasion
Token Theft/Replay	KEEP (OB-004)	PARTIAL; attack exists but GenAI materially amplifies token harvesting, testing, and evasion
Scope Abuse	KEEP (OB-005)	PARTIAL; attack exists but GenAI materially amplifies scope discovery, extraction, and evasion
Data Harvesting	KEEP (OB-006)	PARTIAL; attack exists but GenAI materially amplifies extraction, analysis, and evasion
API Parameter Manipulation	MOVE → Gateway/Processor (GP-001) / Payment Initiation (PI-F001)	Primary mechanism is API parameter manipulation; TPP relationship is incidental
APP Fraud via Open Banking	MOVE → Payment Initiation (PI-F002)	APP fraud is primary; open banking is the channel
TPP/Bank Impersonation	MOVE → Authentication	Credential theft is primary; authentication is the attack surface
Cross-Provider/Cross-Border Exploitation	MOVE → Cross-Stage / Network-Level	Spans multiple TPPs, banks, jurisdictions
AI-Agent Automated Consent Fraud	MOVE → AI-Agent Commerce	Agent autonomy is primary if agent exploits consent
Generic API Injection	DROP	Not payment fraud-specific
TPP Supply Chain Compromise	THEORETICAL	Insufficient real-world evidence; future threat

FINAL METRICS

Metric	Value
Total final attack families	6
Total variants	18+ (across 6 families)
Important candidates kept	Consent Abuse (OB-001); Fake TPP Applications (OB-002); Compromised TPP (OB-003); Token Theft/Replay (OB-004); Scope Abuse (OB-005); Data Harvesting (OB-006)
Important candidates merged	Excessive permissions → OB-005; API credential abuse → OB-003; Malicious fintech → OB-002; Consent revocation abuse → OB-001; Consent duration abuse → OB-001; Refresh token abuse → OB-004; Synthetic TPP identity → OB-002; TPP insider abuse → OB-003
Important candidates moved	API Parameter Manipulation → Gateway/Processor (GP-001) / Payment Initiation (PI-F001); APP Fraud via Open Banking → Payment Initiation (PI-F002); TPP/Bank Impersonation → Authentication; Cross-Provider/Cross-Border Exploitation → Cross-Stage / Network-Level; AI-Agent Automated Consent Fraud → AI-Agent Commerce
Important candidates dropped	Generic API Injection (not payment fraud-specific)

Metric	Value
Theoretical/future threats	TPP Supply Chain Compromise – plausible but insufficient real-world evidence; track for taxonomy expansion
Evidence gaps	Real-world frequency of GenAI-enhanced scope abuse in production; Specific detection evasion effectiveness against production open banking fraud systems; Impact of emerging GenAI architectures on consent deception
Third-party/Open Banking surfaces covered	Consent granting; Consent scope; Customer consent decision; TPP onboarding; TPP-customer trust; TPP operations; TPP API credentials; Delegated access; OAuth token integrity; Consent token security; Consent scope enforcement; Permission model; AISP data access; Financial data privacy; Data extraction patterns; TPP reputation; Consent duration; Consent revocation; TPP-customer relationship; Consent usage
Important surfaces not represented separately	API parameter manipulation (moved to Gateway/Processor/Payment Initiation); APP fraud (moved to Payment Initiation); TPP impersonation (moved to Authentication); Cross-provider abuse (moved to Cross-Stage); AI-agent consent fraud (moved to AI-Agent Commerce)
Existing lifecycle stages that absorb moved attacks	Authentication (AUTH-001, AUTH-002, AUTH-003); Payment Initiation (PI-F001, PI-F002); Gateway/Processor (GP-001); AI-Agent Commerce (AG-001, AG-002, AG-005); Cross-Stage / Network-Level

UNIFYING THEME

The unifying theme across all 6 Third-Party/Open Banking families is the shift from **detectable consent boundaries to indistinguishable delegated access exploitation**. Fraudsters no longer rely on obvious consent manipulation, detectable fake TPPs, or manual data harvesting—they use GenAI to generate:

- **Professional-grade fake TPPs** that appear identical to legitimate providers
- **Hyper-personalised consent deception** that exploits customer trust at scale
- **Adaptive token and scope abuse** that evades monitoring
- **Systematic data harvesting** that leverages AISP access

The core vulnerability is **consent itself**—the mechanism that enables open banking is also its greatest attack surface. Customers authenticate legitimately, but the *consent decision* is manipulated. The bank's systems see a legitimate user, using legitimate credentials, granting legitimate-looking consent. Nothing is "broken" in the authentication layer. The attack occurs in the **gap between what the customer intends and what the consent permits**.

The attack surface has shifted from:

- "Can we break authentication?" → Authentication attacks
- "Can we trick the user?" → Social engineering
- "Can we manipulate the API?" → Gateway/Processor attacks

To:

- **"Can we generate an entirely consent-bound parallel reality that the customer accepts and the system trusts?"**

Fraudsters no longer need to steal credentials or break systems. They can:

- Generate fake TPPs that look identical to legitimate fintechs
- Create consent pages that deceive customers into granting broad access
- Exploit tokens and scopes to access data far beyond what was intended
- Harvest detailed financial profiles at scale

This represents a fundamental change in the threat model: **the customer's consent decision is the primary attack surface, and GenAI makes consent deception indistinguishable from legitimate consent**.

FINAL TAXONOMY COMPARISON

Stage	Number of Families
Identity/KYC	5
Account Creation	3
Device/Session	5
Authentication	4
Payment Initiation	4
Merchant	6

Stage	Number of Families
Acquirer	4
Gateway/Processor	7
Payment Rail	1
Authorization	3
Issuer	(to be researched)
Third-Party / Open Banking	6
AI-Agent Commerce	5
TOTAL (to date)	48 families

The Third-Party/Open Banking taxonomy has **6 families**, emerging naturally from the evidence and the HARD GenAI Removal Test—not forced. This is consistent with other lifecycle stages:

- Merchant: 6 families
- Gateway/Processor: 7 families
- AI-Agent Commerce: 5 families
- Identity/KYC: 5 families
- Device/Session: 5 families

Each of the 6 Third-Party/Open Banking families represents a **distinct attack mechanism** with:

- Load-bearing or strongly partial GenAI transformation
- Strong evidence (VERIFIED)
- Simulation feasibility
- Observable detection signals
- Clear lifecycle distinctness